

Authority for Personal Data
P.O. Box 93374, 2509 AJ The Hague
Hoge Nieuwstraat 8, 2514 EL The Hague
T 070 8888 500 - F 070 8888 501
autoriteitpersoonsgegevens.nl
The Minister of Justice and Security
Mr. D. van Weel
P.O. Box 20301
2500 EH THE HAGUE

Date

July 5, 2024

Our reference

z2024-015226

Your letter dated

May 14, 2024

Contact person

Your reference

5401793

Subject

Legislative assessment draft for the bill on the resilience of critical entities

Dear Mr. Van Weel,

In your letter dated May 14, 2024, the Authority for Personal Data (AP) was consulted based on the provisions of Article 36, fourth paragraph, of the General Data Protection Regulation (GDPR) regarding the draft bill for the implementation of Directive (EU) 2022/2557 of the European Parliament and the Council of December 14, 2022, concerning the resilience of critical entities and repealing Directive 2008/114/EC of the Council (OJ EU 2022, L 333) (hereinafter: the draft).

The AP has several comments on the draft.

Main points

- The draft is insufficiently clear about which personal data, including special categories of personal data, may be processed.
- The draft also does not contain a retention period nor a delegation basis to establish rules in delegated legislation regarding this.

Scope of the draft

The draft aims to implement Directive (EU) 2022/25571 (hereinafter: CER Directive) into Dutch legislation. The purpose of the CER Directive is to support vital societal functions and economic activities in the European Union by ensuring the continuity of the delivery of essential services within the European Union as much as possible. To this end, member states are required to designate competent authorities responsible for periodically conducting a national risk assessment, based on which entities providing essential services in certain sectors and subsectors are identified. The draft designates these entities as critical entities and stipulates that they have a duty of care and a reporting obligation. The draft provides for cooperation between competent authorities and other bodies and specifies that, in this context, data, including personal data, may be exchanged.

Legislative assessment

1. Legal certainty

Cooperation and information exchange

Articles 27a to 30b of the draft stipulate, in summary, that the entities mentioned in those articles must cooperate for the effective and efficient execution of their tasks and that they must exchange all

necessary data, including personal data, among themselves.

Special personal data

Article 31a, first paragraph, of the draft states that the prohibition on processing special categories of personal data, in light of Article 9, second paragraph, introductory phrase and subparagraph g, GDPR, does not apply to processing by the competent authority, insofar as that processing is necessary for the performance of its tasks under the Act on the Resilience of Critical Entities.

Confidential data

Article 32 of the draft regulates the possibility for the entities mentioned therein to provide confidential data to each other and to the authorities mentioned in the article under certain conditions.

An important requirement that also arises from the principle of proportionality and is mentioned in the recitals of the GDPR is that a legal basis or legislative measure for the processing of personal data (and thus an infringement of the right to protection of personal data) must be sufficiently clear and precise, and that the application of that legal basis or legislative measure in practice must be predictable for those to whom it applies.

From the requirement that an interference with the exercise of the right to respect for private life and the protection of personal data must be provided for by law, it follows that such interference must be based on a duly published legal provision from which the citizen can ascertain with sufficient precision which personal data may be collected and recorded for the fulfillment of a specific government task, and under what conditions that data may be processed, retained, and used for that purpose. The regulation itself must therefore be sufficiently specific.

Merely mentioning examples of personal data that may be considered in the explanatory notes of a regulation is not sufficient.

Date

July 5, 2024

Our reference

z2024-015226

3/5

The aforementioned articles regarding cooperation and information exchange do not specify which types of personal data may be exchanged. The draft also lacks a basis to determine this through delegated legislation. It is conceivable that the exercise of a public authority's duties in a particular case is so broad and unpredictable that further clarification of the nature of the special personal data is not possible in advance. In such - rare - cases, the explanation must indicate that this is the case and why it is so. The explanation does not contain such justification in this instance.

From Article 31a of the draft, it cannot be determined which categories of special personal data are involved. Although the second paragraph states that rules may be established by or pursuant to a general administrative regulation regarding the processing of special personal data, this is not mandatorily prescribed.

Article 32 of the draft does not clarify what is meant by confidential data. This is also not defined elsewhere in the draft.

The AP concludes that the draft is not sufficiently clear and precise on the aforementioned points and that the application of the draft on these points is insufficiently predictable, necessitating amendments to Articles 27a through 30b, 31a, and 32 of the legislative text by:

1. including a basis in the legislative text that mandatorily prescribes determining which types of personal data may be exchanged for the purpose of the cooperation referred to in Articles 27a through 30b of the draft;
2. formulating the second paragraph of Article 31a of the draft imperatively and also prescribing that by or pursuant to a general administrative regulation, it is determined which categories of special personal data are necessary for the exercise of the tasks of the competent authority;
3. defining in the draft what is precisely meant by the term 'confidential data' or including a basis in

Article 32 of the draft that mandatorily prescribes determining which data this refers to in delegated legislation.

2. Retention Period

The draft lacks a provision regarding the retention period of personal data processed by the authorities designated in the draft for the execution of their tasks. In paragraph 6.2.2.2 of the explanatory memorandum to the draft, it states that personal data processed by the competent authority (the relevant minister and the supervisory authority) will not be retained longer than necessary. Regarding personal data received by the central contact point, it is stated in paragraph 6.2.2.2 of the explanatory memorandum that the central contact point will assess each time whether it is necessary to retain this data, considering the tasks included in the legislative proposal for the central contact point, and if so, for how long.

According to the Data Protection Impact Assessment (hereinafter: DPIA) accompanying the draft, the current assumption is a retention period of 60 months. This is aligned with the practice of reporting a cyber incident under the Act on the Security of Network and Information Systems (Wbni).

Date

July 5, 2024

Our reference

z2024-015226

4/5

According to Article 5, first paragraph, part e, of the GDPR, personal data may not be retained in a form that allows the identification of data subjects longer than necessary for the purposes for which the personal data are processed. In this regard, the data controller must establish a period for the deletion of data or for periodic review thereof.

The GDPR stipulates that personal data may not be retained longer than necessary for the purposes for which the personal data are processed. A general norm such as this means that it must be specified for specific data processing activities. The AP considers it desirable, from the perspective of legal certainty, that the legislator determines the retention period when making assessments in individual cases is not appropriate and a logical retention period does not clearly follow from the context.

Neither the draft nor the explanatory memorandum to the draft indicates whether, and if so, which retention periods have been established. The draft also does not provide for a delegation basis that allows for the determination of retention periods in delegated legislation. According to the DPIA, a retention period of 60 months would be necessary, but this is not substantiated in the explanatory memorandum.

The AP concludes that it is advisable to include a retention period (possibly in the form of a maximum) in the draft, or in subordinate legislation, regarding personal data processed by the authorities designated in the draft, and to substantiate this in the explanatory memorandum. Special attention should be given to the possibility of differentiated retention periods for the distinct tasks of the designated authorities.

Workload AP

The AP notes that the draft is not expected to require additional effort from the AP.

Publication

This legislative assessment will be published on the AP's website within two weeks.

Yours sincerely,

Authority Personal Data,

Aleid Wolfsen

Chairman

2 Article 5, first paragraph, part e, GDPR.

Date

July 5, 2024

Our reference

z2024-015226

5/5

- Annex

--*--

Assessment Framework AP

The AP examines whether the draft regarding the processing of personal data is in accordance with the Charter of Fundamental Rights of the European Union (EU), the GDPR (Regulation 2016/679), or the Police and Justice Directive (Directive 2016/680), the general legal principles of the EU, and other relevant law, whereby it must be sufficiently demonstrated that the principle of proportionality is met, by:

1. the draft being suitable to achieve the pursued objective of general interest or the protection of the rights and freedoms of others (suitability);
2. the objective cannot reasonably be achieved as effectively by other means that are less intrusive to the fundamental rights of the data subjects (subsidiarity);
3. the interference is not disproportionate to that objective, which particularly implies a weighing of the importance of the objective and the severity of the interference (proportionality);
4. the draft is sufficiently clear and precise regarding its scope and is predictable in its application (legal certainty);
5. the draft sufficiently indicates under what circumstances and conditions personal data may be processed, thereby ensuring that the interference is limited to what is strictly necessary (substantive and procedural safeguards); and
6. the draft is binding under national law (bindingness under national law).

The AP pays particular attention to the rights of data subjects and the compliance of the draft with Article 6, paragraphs 1 and 3, and Article 9 of the GDPR (Regulation 2016/679), or Articles 8 and 10 of the Police and Justice Directive (Directive 2016/680) and with the principles established in Article 5 of the GDPR or Article 4 of the Directive. This implies, among other things, that:

- (a) processing must be lawful, fair, and transparent in relation to the data subject;
- (b) personal data may only be collected for specified, explicitly defined, and legitimate purposes; and
- (c) processing must be adequate, relevant, and limited to what is necessary for the purposes.

--*--